

Security Audit

CrossCurve (DeFi)

Table of Contents

Executive Summary	4
Project Context	4
Audit Scope	7
Security Rating	8
Intended Smart Contract Functions	9
Code Quality	10
Audit Resources	10
Dependencies	11
Severity Definitions	11
Status Definitions	12
Audit Findings	13
Centralisation	18
Conclusion	19
Our Methodology	20
Disclaimers	22
About Hashlock	23

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

The CrossCurve team partnered with Hashlock to conduct a security audit of their smart contracts. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

CrossCurve is a decentralized cross-chain DeFi infrastructure protocol that provides a unified "MetaLayer" for accessing liquidity, swaps, and yield opportunities across multiple blockchains. Instead of operating as a single DEX or bridge, it aggregates multiple DEXs, bridges, and liquidity sources into one routing layer, enabling users to swap any token across chains with optimized pricing and minimal slippage. The platform also includes components such as a cross-chain DEX, token bridge, oracle/messaging network, and liquidity pools powered by Curve, aiming to solve liquidity fragmentation and enable seamless, secure interoperability across the DeFi ecosystem.

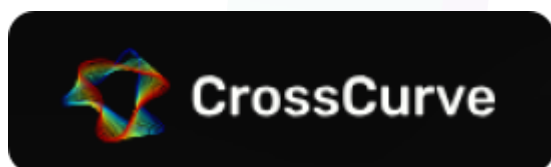
Project Name: CrossCurve

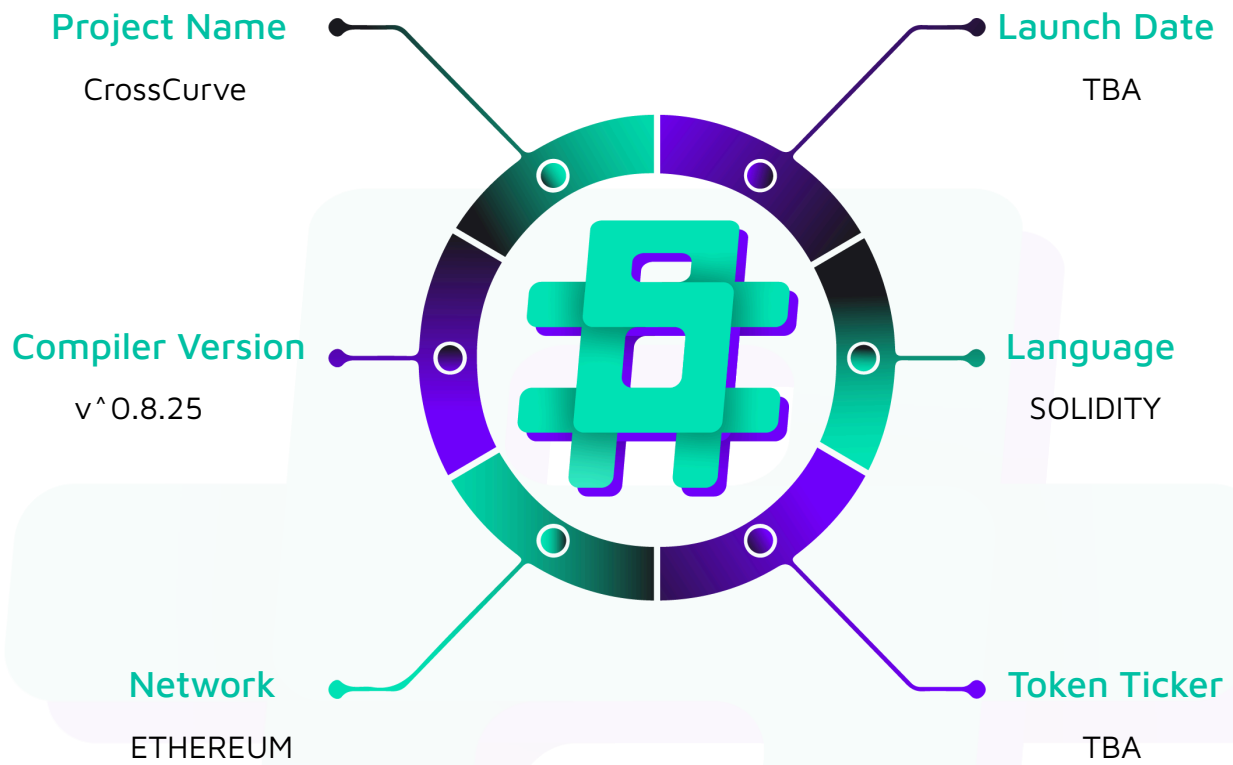
Project Type: Defi

Compiler Version: ^0.8.25

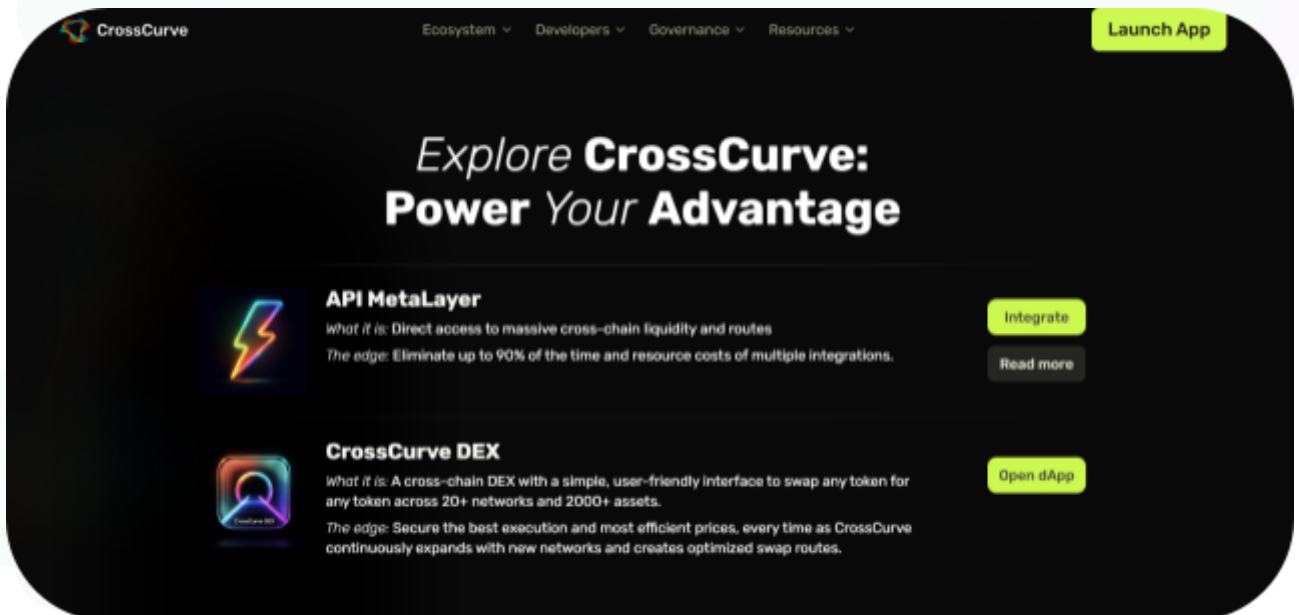
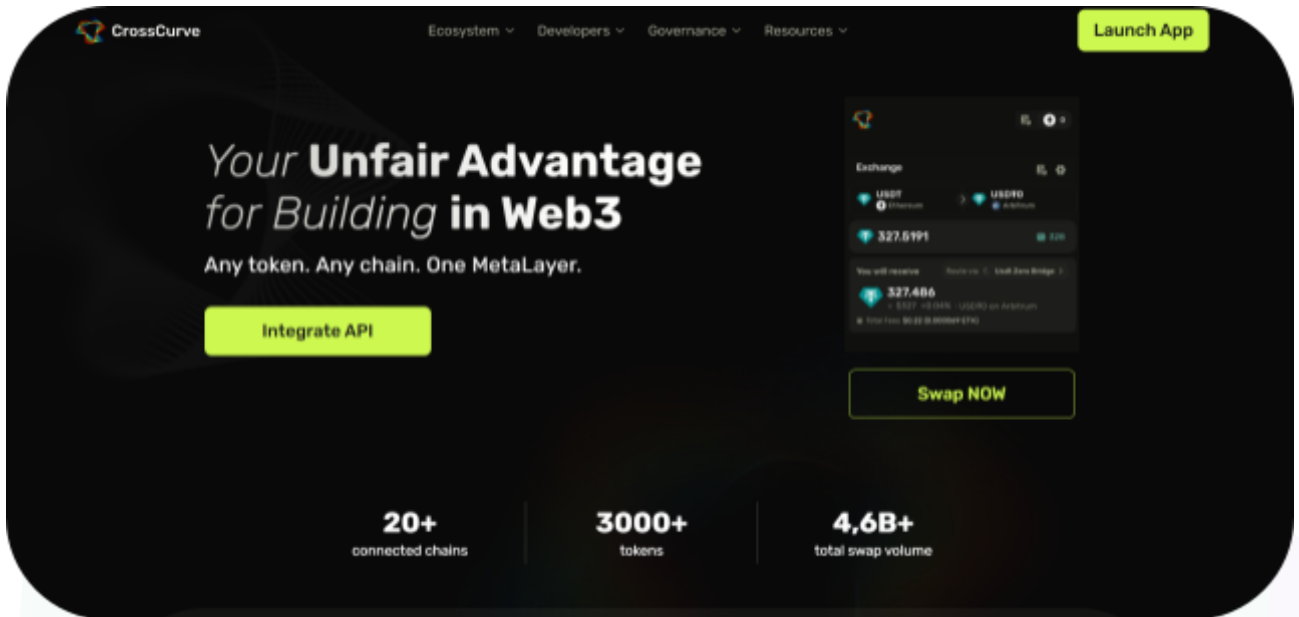
Website: <https://crosscurve.fi/>

Logo:



Visualised Context:

Project Visuals:



Audit Scope

We at Hashlock audited the solidity code within the CrossCurve project, the scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	CrossCurve Smart Contracts
Network	Ethereum
Language	Solidity
Audit Date	March, 2026
Contract 1	CrossCurveCore.sol
Contract 2	MintBurnOFTAdapter.sol
Contract 3	OFTAdapter.sol
Contract 4	CrossCurveOFTStorage.sol
Contract 5	OptionReader.sol

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering. They use a series of interfaces, and the protocol uses a list of Open Zeppelin contracts.



The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the [Audit Findings](#) section. The list of audited assets is presented in the [Audit Scope](#) section and the project's contract functionality is presented in the [Intended Smart Contract Functions](#) section.

All vulnerabilities initially identified have now been resolved.

Hashlock found:

1 Medium severity vulnerabilities

3 Low severity vulnerabilities

1 QA

Caution: *Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.*

Intended Smart Contract Functions

Claimed Behaviour	Actual Behaviour
CrossCurveCore.sol Extends LayerZero OFTCore for CrossCurve. For destinations with crossCurveEnabled routes sends through GateKeeper instead of _lzSend(). Incoming CrossCurve messages are validated by receiveValidatedData(), then crossCurveReceive() runs _lzReceive().	Contract achieves this functionality.
OFTAdapter.sol Extends CrossCurveCore, pulls tokens on send and unlocks on receive.	Contract achieves this functionality.
MintBurnOFTAdapter.sol Extends CrossCurveCore, uses IMintableBurnable to burn on send and mint on receive (no user approval).	Contract achieves this functionality.
CrossCurveOFTStorage.sol Library using transient storage for the current CrossCurve message context	Contract achieves this functionality.
OptionsReader.sol Library that parses LayerZero executor options (fork of ExecutorFeeLib logic) and exposes gas limit calculation for CrossCurve fee building.	Contract achieves this functionality.

Code Quality

This audit scope involves the smart contracts of the CrossCurve project, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices and to help avoid unnecessary complexity that increases the likelihood of exploitation, however, some refactoring were recommended to optimize security measures.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the CrossCurve project smart contract code in the form of GitHub access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.

Apart from libraries, its functions are used in external smart contract calls.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-severity issues should be resolved before deployment. While they do not typically lead to a complete loss of funds, they may result in partial loss of funds or unintended behavior under certain conditions.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies.
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue.
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

Medium

[M-01] CrossCurveCore#_send - Native value locked when cross curve enabled

Description

CrossCurveCore._send() does not validate that msg.value is zero when routing through the CrossCurve path, leaving any native fee sent by the caller with no forwarding path and no refund.

Vulnerability Details

OFTCore.send() is payable, accepting native assets to cover LayerZero messaging fees. CrossCurveCore overrides _send() and branches on crossCurveEnabled[_sendParam.dstEid]. When false, _lzSend() is called, forwarding msg.value to the LayerZero endpoint and refunding any excess to _refundAddress. When true, gateKeeper.sendData() is called instead, msg.value is neither forwarded nor returned.

A user can send msg.value by mistake or in an edge case scenario where the user calls quoteSend() while crossCurveEnabled[dstEid] is false (receiving a non-zero nativeFee), and then the owner enables CrossCurve for that destination before the user's send() transaction executes. In that case the contract routes through the CrossCurve path and the user's msg.value is neither forwarded nor refunded.

Impact

Any native asset sent by a user is permanently locked in the contract if crossCurveEnabled is set to true.

Recommendation

Add a check at the start of the CrossCurve branch that reverts if `msg.value` is non-zero. Also, consider documenting in `_send()` that the parameters `_fee` and `_refundAddress` are not used for CrossCurve cases.

Status

Resolved

Low

[L-01] CrossCurveCore#_send - No event emitted on CrossCurve path

Description

The `_send()` function emits an event on the standard LayerZero path but emits nothing on the CrossCurve path, leaving CrossCurve routed transfers unobservable off-chain.

Vulnerability Details

`_send()` branches on `crossCurveEnabled[_sendParam.dstEid]`. On the `false` branch, it emits `0FTSent` after dispatching via LayerZero. On the `true` branch, it dispatches through `gateKeeper.sendData()` and returns without emitting any event.

Impact

Off-chain services will silently miss all CrossCurve routed transfers, producing incorrect tracking and unreliable event driven workflows.

Recommendation

Define and emit a dedicated event for CrossCurve routed sends.

Status

Resolved

[L-02] CrossCurveCore#receiveValidatedData - Missing selector validation

Description

`receiveValidatedData` accepts a `selector` parameter but never validates it, missing the intended check that the selector matches `crossCurveReceive`.

Vulnerability Details

`receiveValidatedData` authenticates an incoming cross chain call before the Receiver invokes the target function. The interface takes a `selector` argument so it can confirm the call is destined for the expected function. However, the parameter is silently ignored.

Impact

Any call to `receiveValidatedData` with an arbitrary selector succeeds and writes transient auth state for a function the contract never intended to authenticate.

Recommendation

Reject any selector that is not `CrossCurveCore.crossCurveReceive.selector`.

Status

Resolved

[L-03] CrossCurveCore#_send - Uninitialized msgReceipt returned on crossCurve path

Description

When a destination EID has crossCurve enabled, `_send()` returns a zero value `MessagingReceipt` to callers instead of a populated one.

Vulnerability Details

`_send()` declares `msgReceipt` as a named return variable and populates it only in the standard `LayerZero` branch, via `_lzSend()`. In the `crossCurve` branch, `gateKeeper.sendData()` dispatches the cross chain message but `msgReceipt` is never assigned.

The function returns with `msgReceipt.guid == bytes32(0)`, `msgReceipt.nonce == 0`, and both fee fields at zero for every send that goes through the `crossCurve` path.

Impact

Any on-chain or off-chain caller that relies on the returned `MessagingReceipt`, receives a fully zeroed struct.

Recommendation

Construct and assign a `MessagingReceipt` from the data available in the cross curve path.

Status

Resolved

QA

[Q-01] CrossCurveOFTStorage - Unused GASLIMIT_POS constant

Description

GASLIMIT_POS is declared as a private constant but never referenced anywhere in the library.

Vulnerability Details

The library defines four transient storage slot constants. The first three each have a dedicated setter and getter that use `tstore/tload`. GASLIMIT_POS has no function in the library that reads or writes to this slot.

Impact

The constant implies a gas limit mechanism exists when none does, causing reviewers to expect getter/setter functions that are absent.

Recommendation

Remove the GASLIMIT_POS declaration.

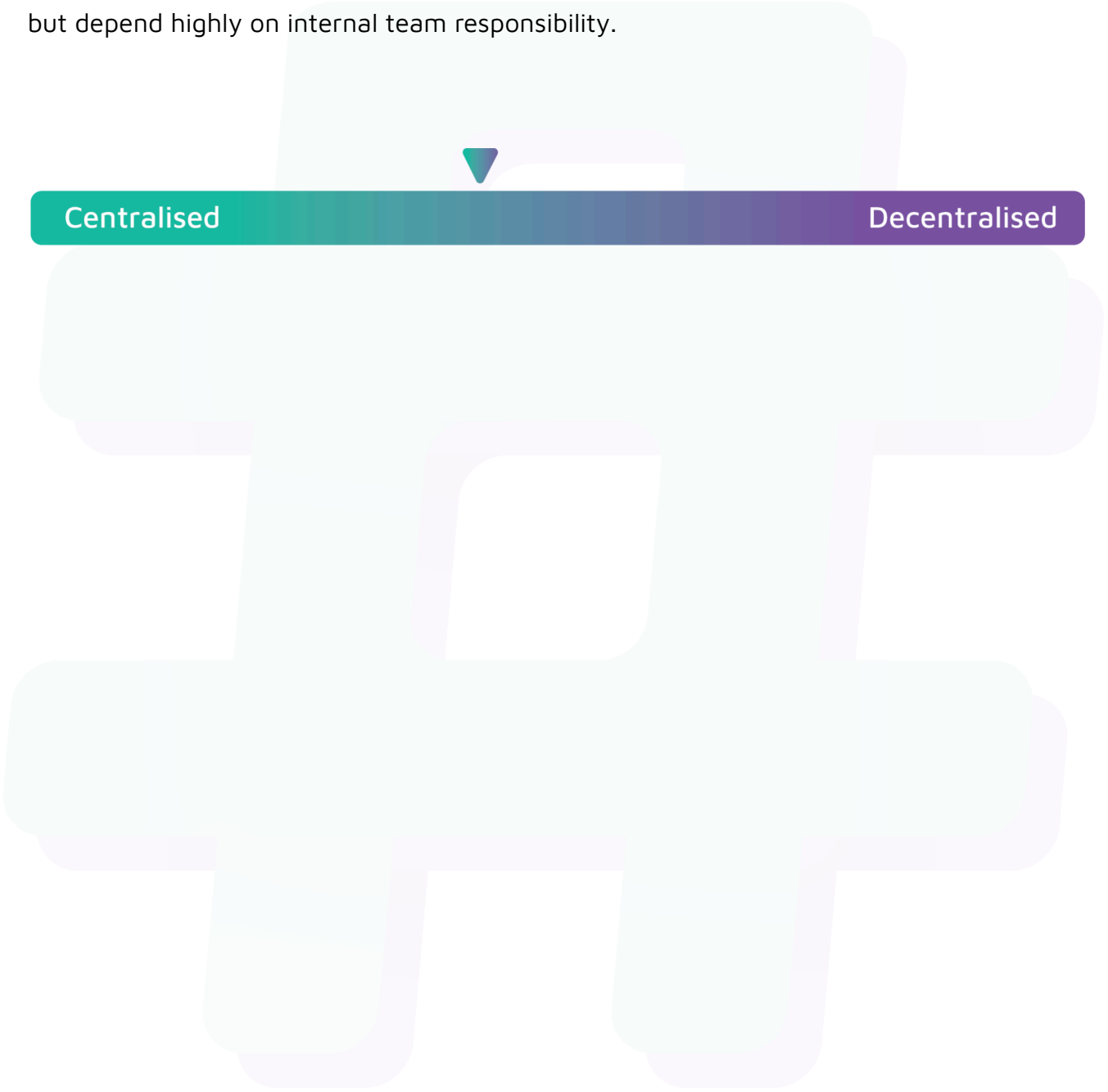
Status

Resolved

Centralisation

The CrossCurve project values security and utility over decentralisation.

The owner executable functions within the protocol increase security and functionality but depend highly on internal team responsibility.



Centralised

Decentralised

Conclusion

After Hashlock's analysis, the CrossCurve project seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au

Contact: info@hashlock.com.au



#hashlock.